

ShopSphere

S1 - Customer Authentication and Account Security

Customer Portal

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S1 - Customer Authentication and Account Security

Platform: Customer Portal

Application: ShopSphere

Objective: Implement the customer authentication screens and session behavior on iOS, Android and Web.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-CP-01-01	Register account	New customer	Registration screen available	Enter required details, submit, verify OTP	Customer reaches authenticated/verified state.
UC-CP-01-02	Login	Existing customer	Valid account	Enter credentials or OTP	Customer reaches home entry point with active session.
UC-CP-01-03	Restore session	Returning customer	Refresh token exists	Launch app/web, refresh session	Customer remains signed in without re-entering credentials.

3. Detailed Implementation Plan

1. Create authentication feature module.
2. Implement registration form with client-side field validation.
3. Implement OTP screen with resend countdown and retry state.
4. Implement login with supported modes.
5. Implement forgot/reset password screens.
6. Store tokens only through secure abstraction.
7. Implement startup session restoration and token refresh.
8. Implement logout and navigation reset.
9. Implement platform-specific secure storage adapters where required.
10. Add analytics/logging hooks without sensitive payloads.

4. Data / State / Contract Scope

- No direct database access. Client consumes backend identity models.

API / Integration Contract

- POST /api/v1/auth/register
- POST /api/v1/auth/send-otp
- POST /api/v1/auth/verify-otp
- POST /api/v1/auth/login
- POST /api/v1/auth/logout
- POST /api/v1/auth/refresh
- POST /api/v1/auth/forgot-password
- POST /api/v1/auth/reset-password
- GET /api/v1/users/me

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.

- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- A customer can register on all three targets.
- OTP expiry/resend states are clear.
- Login failures are user-friendly without exposing backend details.
- Session restoration works after app/browser restart.
- Logout clears local authenticated state.

7. Test Cases

TC	Scenario	Expected Result
TC-S1-01	Required-field validation	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-02	Invalid email	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-03	Weak password	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-04	Wrong OTP	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-05	Expired OTP	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-06	Resend countdown	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-07	Wrong password	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-08	Session restore	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-09	Expired access token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-10	Logout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-11	Network timeout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-12	Backend 500	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.
- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Backend + DB. That behavior belongs in the separate S1 document for that platform.

- Implementation behavior of Admin Portal. That behavior belongs in the separate S1 document for that platform.